AWS Verified Access Security

NETWORKING

AWS Verified Access provides secure access to corporate applications without requiring a VPN. It evaluates each access request in real time against Cedar policies using identity and device posture data from configured trust providers. Compromising it means bypassing zero-trust enforcement entirely.

MEDIUM	Regional	Cedar	RBAC + ABAC
Risk Level	Scope	Policy Language	Auth Model

📋 Service Overview

Core Components

Verified Access Instance (top-level resource), Trust Providers (identity + device posture), Groups (collections of endpoints sharing a policy), and Endpoints (individual applications). Uses Cedar policy language.

Attack note: An attacker who can modify group or endpoint policies, or attach a trust provider they control, can grant themselves access to every protected application.

Cedar Policies and Trust Providers

Cedar policies default to implicit deny. Group-level policies are inherited by all endpoints. One identity trust provider (IAM Identity Center or OIDC) and multiple device trust providers (CrowdStrike, Jamf, JumpCloud) per instance.

Attack note: An overly broad permit statement at the group level with no endpoint-level restrictions grants access to all endpoints in that group.

Security Risk Assessment

6.5

Risk Score

Verified Access is a protective control, not a data store. The primary risk is misconfiguration that weakens or bypasses access enforcement. Compromise of the trust provider or overly permissive Cedar policies can expose all protected applications.

⚔️ Attack Vectors

Trust Provider Abuse

- Compromise OIDC identity provider to issue valid tokens
- Register a rogue device trust provider
- Exploit misconfigured OIDC scopes or claims
- Steal or replay user session tokens
- Target IdP admin console to add attacker users

Policy & Config Manipulation

- Modify group policy to blanket permit statement
- Disable policy on endpoint (--no-policy-enabled)
- Create new endpoint in permissive group
- Attach attacker-controlled trust provider
- Delete endpoint to force less secure fallback

⚠️ Misconfigurations

Policy Weaknesses

- Group policy uses permit(principal, action, resource) with no conditions
- Endpoint policy not enabled (PolicyEnabled: false)
- Cedar policy checks identity but ignores device posture
- Policy references nonexistent trust provider context key
- No endpoint-level policy refinement

Operational Gaps

- Access logging not enabled on instance
- Trust provider not validated (misconfigured OIDC URL)
- No device trust provider attached
- Instance has no tags or naming convention
- Endpoints exposed to broader network than intended

🔍 Enumeration

List Verified Access Instances

```
aws ec2 describe-verified-access-instances
```

List Trust Providers

```
aws ec2 describe-verified-access-trust-providers
```

List Verified Access Groups

```
aws ec2 describe-verified-access-groups
```

Get Group Policy (Cedar)

```
aws ec2 get-verified-access-group-policy \
  --verified-access-group-id vagr-0dbe967baf14b7235
```

Check Logging Configuration

```
aws ec2 describe-verified-access-instance-logging-configurations \
  --verified-access-instance-ids vai-0ce000c0b7643abea
```

📈 Privilege Escalation

Policy Escalation

- ModifyVerifiedAccessGroupPolicy to blanket permit
- ModifyVerifiedAccessEndpointPolicy to disable enforcement
- CreateVerifiedAccessEndpoint for sensitive internal resources
- AttachVerifiedAccessTrustProvider (attacker-controlled)
- CreateVerifiedAccessTrustProvider with rogue OIDC issuer

Key insight: Verified Access itself is not a path to IAM privilege escalation. However, modifying policies grants access to all protected internal applications.

🔗 Persistence

Access Bypass

- Replace Cedar group policy with blanket permit
- Disable endpoint-level policy enforcement
- Attach attacker-controlled trust provider
- Create endpoints in permissive groups
- Modify instance descriptions to obscure audit trail

Maintaining Access

- Generate fabricated device posture data
- Exploit OIDC token issuance from compromised IdP
- Create new endpoints pointing to internal resources
- Keep access logging disabled
- Modify trust provider to accept broader claims

🛡️ Detection

High-Impact CloudTrail Events

- ModifyVerifiedAccessGroupPolicy - policy changed
- ModifyVerifiedAccessEndpointPolicy - endpoint policy changed
- CreateVerifiedAccessTrustProvider - new trust provider
- AttachVerifiedAccessTrustProvider - provider attached
- DeleteVerifiedAccessEndpoint - endpoint removed

Access Log Indicators

- Access from unexpected IP addresses
- Failed policy evaluations from new principals
- Successful access without device posture context
- Bulk endpoint creation or modification
- Trust provider configuration changes

💻 Exploitation Commands

Replace Group Policy with Blanket Permit

```
aws ec2 modify-verified-access-group-policy \
  --verified-access-group-id vagr-XXXXX \
  --policy-enabled \
  --policy-document "permit(principal, action, resource);"
```

Disable Endpoint Policy

```
aws ec2 modify-verified-access-endpoint-policy \
  --verified-access-endpoint-id vae-XXXXX \
  --no-policy-enabled
```

Create Rogue Trust Provider

```
aws ec2 create-verified-access-trust-provider \
  --trust-provider-type user \
  --user-trust-provider-type oidc \
  --oidc-options Issuer=https://
attacker.example.com,AuthorizationEndpoint=...,TokenEndpoint=...
```

Attach Trust Provider to Instance

```
aws ec2 attach-verified-access-trust-provider \
  --verified-access-instance-id vai-XXXXX \
  --verified-access-trust-provider-id vatp-XXXXX
```

📜 Policy Examples

✗ Dangerous - Unrestricted Policy Modification

```
{
  "Effect": "Allow",
  "Action": [
    "ec2:ModifyVerifiedAccessGroupPolicy",
    "ec2:ModifyVerifiedAccessEndpointPolicy",
    "ec2:CreateVerifiedAccessTrustProvider"
  ],
  "Resource": "*"
}
```

Grants unrestricted ability to rewrite Cedar policies and attach arbitrary trust providers

✓ Secure - Read-Only Auditor

```
{
  "Effect": "Allow",
  "Action": [
    "ec2:DescribeVerifiedAccessInstances",
    "ec2:DescribeVerifiedAccessGroups",
    "ec2:DescribeVerifiedAccessEndpoints",
    "ec2:GetVerifiedAccessGroupPolicy"
  ],
  "Resource": "*"
}
```

Permits enumeration and policy review without ability to modify access controls

🛡️ Defense Recommendations

📝 Enable Access Logging on Every Instance

Send Verified Access logs to CloudWatch Logs, S3, or Kinesis Data Firehose for audit.

```
aws ec2 modify-verified-access-instance-logging-configuration \
  --verified-access-instance-id vai-XXXXX \
  --access-logs S3={Enabled=true,BucketName=my-va-logs-bucket}
```

📱 Attach Both Identity and Device Trust Providers

Never rely on identity alone. Attach at least one device trust provider (CrowdStrike, Jamf, JumpCloud) for device posture checks.

📜 Write Restrictive Cedar Policies

Use group-level policies for broad requirements and endpoint-level policies for application-specific conditions.

🔒 Restrict IAM Permissions for Modification

Limit ec2:ModifyVerifiedAccess*, ec2:CreateVerifiedAccess*, and ec2:AttachVerifiedAccessTrustProvider to administrators.

🔍 Monitor CloudTrail for Policy Changes

Alert on ModifyVerifiedAccessGroupPolicy, CreateVerifiedAccessTrustProvider, and DeleteVerifiedAccessEndpoint.

✅ Validate Trust Provider Configuration

Audit OIDC issuer URL, client ID, and scopes on identity trust providers regularly.

AWS Verified Access Security Security Card

Always obtain proper authorization before testing